Hướng dẫn tổng quan về Hashcat

Để vắt kiệt công dụng của phần mềm , ta cần làm chủ 4 thành phần cốt lõi :

- Chế độ tấn công (Attack Modes)
- Các thuật toán băm thông dụng
- Bộ lọc quy tắc (Rules)
- Các kỹ thuật tối ưu hóa phần cứng

1) Chế độ tấn công cốt lõi (-a)

-a 0 | Straight (Tấn công từ điển): Thử nghiệm từng từ trong 1 file Wordlist (ví dụ: rockyou.txt)

-a 1 | Combination (Kết hợp từ điển): Ghép các từ từ 2 file từ điển lại với nhau(Ví dụ: file 1 có admin , file 2 có 123 => sinh ra admin123

-a 3 |Brute-force / Mask (tấn công theo mặt nạ): Đây là chế độ mạnh nhất nếu ta nhớ 1 phần mật khẩu. Dùng các ký tự đại diện để tạo bộ khung:

- ?l : Ký tự thường (a-z)
- ?u: Ký tự in hoa (A-Z)
- ?d: Chữ số (0-9)
- ?s: Ký tự đặc biệt (!,@,#,...)
- ?a: Tất cả các loại trên

Ví dụ : Đoán mã băm gói mạng của aircrack-ng (mode 22000 với file hash.hc22000) với chế độ Brute-force / mask:

Lệnh Linux: hashcat -m 22000 myhash.hc22000 -a 3 --increment-min 8 --increment-max 12 -1 ?l?d ?1?1?1?1?1?1?1?1?1?1?1?1

Lệnh Windows: .\hashcat.exe -m 22000 myhash.hc22000 -a 3 --increment --increment-min 8 --increment-max 12 -1 ?l?d ?1?1?1?1?1?1?1?1?1?1?1?1

-a 6|Hybrid Dict + Mask: Lấy 1 từ trong từ điển rồi thêm các ký tự băm/mặt nạ vào phía sau (Ví dụ: Password?d?d => Passwoed12)

-a 7|Hybrid Mask + Dict: Ngược lại với -a 6 , thêm mặt nạ vào phía trước từ tiển

2) Các thuật toán băm (Hash Types) thông dụng khác (-m)

Ngoài wifi (-m 22000) , Hashcat hỗ trợ hơn 300 loại mã hóa khác nhau.

Mã số -m	Loại Hash / Ứng dụng thực tế	Chú ý
-m 0	**MD5** (Thường gặp trong các database cũ, mã nguồn web PHP)	**Webex ctf**
-m 11	**(Joomla < 2.5.18):** Dạng md5($pass.$salt).	**Webex ctf**
-m 100	**SHA-1** (Hệ thống Git, các chứng chỉ cũ)	
-m 400	**(WordPress / phpBB3)**: Gặp nhiều trong các bài web CMS.Chuỗi hash thường có dạng P9... hoặc H9 ...	**Webex ctf**
-m 500	**(md5crypt1):** Hệ thống Linux cũ hoặc mật khẩu nén trong một số firmware Router/IoT	
-m 1000	**(NTLM):** Mật khẩu Windows cục bộ. Tốc độ bẻ NTLM trên GPU cực kỳ khủng khiếp (hàng tỷ hash/giây), bạn có thể brute-force độ dài lớn.	
-m 1400	**SHA-256** (Phổ biến nhất hiện nay trong bảo mật hệ thống)	**Webex ctf**
-m 1410	**(SHA-256 salt):** Phổ biến trong các framework web hiện đại tự tùy biến (Custom salt)	
-m 1420	**Salt SHA-256:**Phổ biến trong các framework web hiện đại tự tùy biến (Custom salt)	
-m 1700	**SHA-512** (Cực kỳ bảo mật, dùng mã hóa mật khẩu sâu)	
-m 1800	**SHA512crypt 6** (Mật khẩu hệ thống **Linux / Ubuntu**)	
-m 1000	**NTLM** (Mật khẩu tài khoản **Windows / Active Directory**)	

-m 3200	***(bcrypt 2, 2a, 2b):*** Thuật toán băm cực kỳ "trâu bò" và tốn phần cứng, thường dùng trong Laravel (PHP), Ruby on Rails, Node.js	**Webex ctf**
-m 3900	***md5(md5($pass).$salt)***	**Webex ctf**
-m 4700	***md5(sha1($pass))***	**Webex ctf**
-m 4800	***md5(md5($pass))***	**Webex ctf**
-m 6200	**(TrueCrypt)**Mã hóa ổ đĩa mã nguồn mở	
-m 9400 đến -m 9600	***(MS Office 2007/2010/2013):*** *Khôi phục mật khẩu file Word. Excel. PowerPoint bị khóa*	**Forensic ctf**
-m 11300	***Bitcoin WIF private key***	
-m 15700	***Ethereum Wallet***	
-m 12000	**(PBKDF2-HMAC-SHA256):** Thường gặp trong các hệ thống Django (Python) hoặc các ứng dụng Node.js hiện đại	**Webex ctf**
-m 13000	**(RAR5):** Chuỗi hash bắt đầu bằng $rar5$	**Forensic ctf**
-m 13700	**(VeraCrypt)**Mã hóa ổ đĩa mã nguồn mở	**Full disk encrypt** **Forensic ctf**
-m 16500	**(JWT(JSON Web Token)):** Copy nguyên chuỗi JWT thu được từ Cookie (header.payload.signature) bỏ vào file jwt.txt rồi chạy:hashcat -m 16500 jwt.txt -a 3 ?l?l?l?d?d # Brute-force key gồm 3 chữ thường 2 số	**Webex ctf**
-m 17200	**(PKZIP / WinZip):** Dạng file zip cũ	**Forensic ctf**
-m 22000	Bẻ khóa các gói mạng của aircrack-ng	
-m 22100	**BitLocker** (Khôi phục mật khẩu phân vùng ổ cứng Windows mã hóa)	**Full disk encrypt** **Forensic ctf**
-m 23000	**(SecureZIP AES):** Dạng file zip mã hóa AES hiện đại	**Forensic ctf**
-m 17210	**PKZIP / WinZip** (Bẻ khóa file nén ZIP)	
-m 16200	**Apple PDF** (Mật khẩu file tài liệu PDF mã hóa)	**Full disk encrypt** **Forensic ctf**
-m 29400	**(Apple File System -APFS):** Bản dump ổ đĩa của hệ điều hành macOS	**Crypto Wallets** **Forensic ctf**

3) Quy tắc đổi từ (Rules)

Ta có thể sử dụng các file rule có sẵn đi kèm khi cài đặt Hashcat (thường nằm trong thư mục rules/):

- Best64.rule : Thử 64 biến thể phổ biến nhất (viết hoa chữ cái đầu , thêm số 1 vào cuối ...)
- dive.rule : Bộ rule cực lớn , biến đổi sâu (thay thế chữ cái thành ký tự tương đương như a thành @ , i thành 1).

Ví dụ cú pháp : hashcat -m 0 -a 0 target_hash.txt rockyou.txt -r rules/best64.rule

4) Các tham số tối ưu hóa phần cứng và Quản lý nâng cao

Các lệnh để tăng tốc độ tính toán (H/s -Hashes per second) lên mức tối đa hoặc quản lý quá trình bẻ khóa dài :

- -w 4 (Workload Profile): Ép GPU hoạt động ở công suất tối đa (mức 4) . Máy tính sẽ bị giật lag nặng nhưng tốc độ bẻ khóa là nhanh nhất.
- -o (Optimized Kernels) Kích hoạt nhân tối ưu hóa. Tăng tốc đáng kể nhưng giới hạn độ dài mật khẩu (thường tối đa 32 ký tự).
- --session <tên_phiên> : Đặt tên cho phiên chạy . Nếu phải tắt máy , lần sau chỉ cần gõ lại lệnh kèm theo --restore để chạy tiếp từ vị trí cũ mà không phải làm lại từ đầu.
- --show :Hiển thị mật khẩu đã bẻ khóa thành công từ file lịch sử (hashcat.potfile) thay vì chạy lại.

5) Ứng dụng trong web exploitation

Trong các bài toán Web, sau khi bạn SQL Injection thành công và thu được Database, hoặc đọc được file cấu hình (config.php, .env), bạn sẽ cần các chế độ sau để tìm mật khẩu Admin hoặc giải mã Cookie/Session.

Các thuật toán băm Database & CMS phổ biến (-m)

- **-m 0 (MD5) | -m 100 (SHA-1) | -m 1400 (SHA-256):** Các dạng băm thô cơ bản trong các web tự code hoặc database đời cũ.
- **-m 400 (WordPress / phpBB3):** Gặp cực nhiều trong các bài Web CMS. Chuỗi hash thường có dạng P9... hoặc H9....
- **-m 11 (Joomla < 2.5.18):** Dạng md5($pass.$salt).

- **-m 1410 (SHA-256 \(salt) \vert{} `-m 1420` (\)salt SHA-256):** Rất phổ biến trong các framework web hiện đại tự tùy biến (Custom Salt).
- **-m 12000 (PBKDF2-HMAC-SHA256):** Thường gặp trong các hệ thống Django (Python) hoặc các ứng dụng Node.js hiện đại.
- *-m 3200 (bcrypt 2, 2a, 2b):** Thuật toán băm cực kỳ "trâu bò" và tốn phần cứng, thường dùng trong Laravel (PHP), Ruby on Rails, Node.js. *Mẹo:* Gặp loại này trong giải đấu ngắn hạn thì hãy ưu tiên dùng Wordlist rất nhỏ + Rule ngắn, vì tốc độ bẻ bcrypt trên GPU rất chậm so với MD5.

  Tấn công mã hóa JWT (JSON Web Tokens)

  Trong Web CTF, việc làm giả JWT để leo quyền Admin là một dạng bài kinh điển. Nếu JWT sử dụng thuật toán mã hóa đối xứng **HS256**, bạn có thể dùng Hashcat để brute-force tìm Secret Key.
- **Chế độ: -m 16500 (JWT (JSON Web Token))**
- **Cách dùng:** Bạn copy nguyên chuỗi JWT thu được từ Cookie (header.payload.signature) bỏ vào file jwt.txt rồi chạy:
  hashcat -m 16500 jwt.txt -a 3 ?l?l?l?d?d # Brute-force key gồm 3 chữ thường 2 số

  Bẻ khóa Hash có Salt đặc biệt trong Source Code

  Nếu bạn đọc được mã nguồn và thấy Web hash mật khẩu theo một công thức kỳ lạ (Ví dụ: md5(sha1($pass))), Hashcat hỗ trợ các chế độ kết hợp (Combinations):
- **-m 4700**: md5(sha1($pass))
- **-m 4800**: md5(md5($pass))
- **-m 3900**: md5(md5($pass).$salt)

6) Ứng dụng trong Forensic

Trong Forensic, bạn thường nhận được một file Image ổ đĩa (.E01, .raw, .dd), file dump bộ nhớ (.raw, .dmp), hoặc các file nén, tài liệu bị khóa. Mục tiêu là trích xuất hash từ các file này và dùng Hashcat để "bẻ".

File nén và Tài liệu văn phòng mã hóa (Crypto / Archives)

Để bẻ khóa các file này, bạn phải dùng các công cụ thuộc bộ John the Ripper (như zip2john, rar2john, office2john) để lấy chuỗi hash ra trước, sau đó đưa vào Hashcat.

- **-m 13000 (RAR5):** Chuỗi hash bắt đầu bằng $rar5$.
- **-m 17200 (PKZIP / WinZip):** Dạng file zip cũ.
- **-m 23000 (SecureZIP AES):** Dạng file zip mã hóa AES hiện đại.
- **-m 9400 đến -m 9600 (MS Office 2007 / 2010 / 2013):** Khôi phục mật khẩu file Word, Excel, PowerPoint bị khóa.

Khôi phục mật khẩu Hệ điều hành (Windows / Linux)

Khi bạn dump được file SAM và SYSTEM (Windows) hoặc file /etc/shadow (Linux) từ một ảnh đĩa:

- **-m 1000 (NTLM):** Mật khẩu Windows cục bộ. Tốc độ bẻ NTLM trên GPU cực kỳ khủng khiếp (hàng tỷ hash/giây), bạn có thể brute-force độ dài lớn.
- **-m 1800 (sha512crypt 6):** Mật khẩu mặc định của đa số các bản phân phối Linux (Ubuntu, Debian, CentOS).
- **-m 500 (md5crypt 1):** Hệ thống Linux đời cũ hoặc mật khẩu nén trong một số firmware Router/IoT.

3. Mã hóa toàn bộ ổ đĩa (Full Disk Encryption - FDE)

Các bài Forensic nâng cao thường bắt bạn giải mã một phân vùng ẩn. Bạn dùng script python (như bitlocker2john, vnc2john) để trích xuất metadata hash:

- **-m 22100 (BitLocker):** Ổ cứng mã hóa của Windows.
- **-m 13700 (VeraCrypt) / -m 6200 (TrueCrypt):** Các phần mềm mã hóa ổ đĩa mã nguồn mở phổ biến trong CTF.
- **-m 29400 (Apple File System - APFS):** Bản dump ổ đĩa của hệ điều hành macOS.

  4. File cấu hình ví tiền điện tử (Crypto Wallets)

  Đôi khi bài Forensic yêu cầu bạn khôi phục mật khẩu ví Bitcoin/Ethereum nằm trong thư mục ứng dụng:
- **-m 11300**: Bitcoin WIF private key.
- **-m 15700**: Ethereum Wallet.